Cybersecurity: Technologies, Threats and Defenses– Lab 1.1

Ritu Pujari

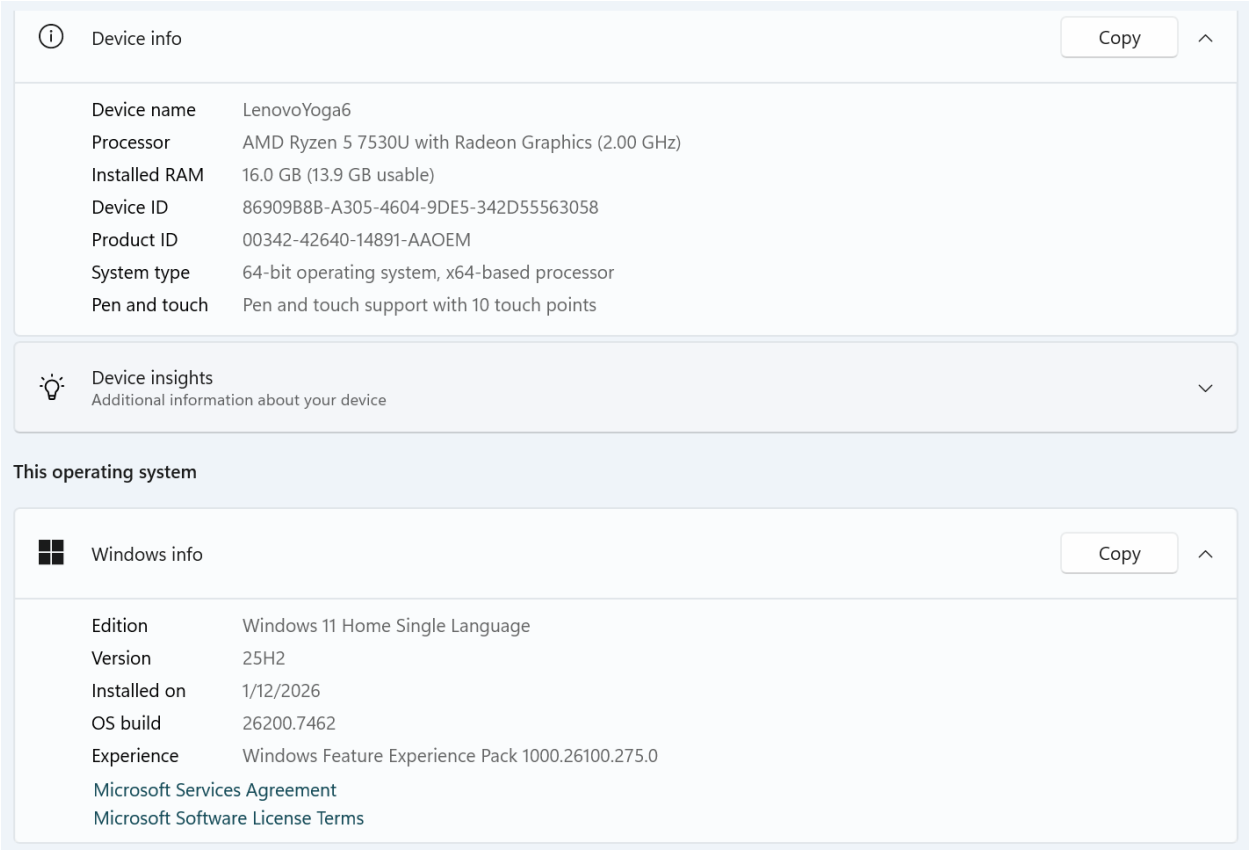
Table of Contents:

Part 1 – Introduction 2
1. Description of Computer (Hardware and OS Details) 2
..... 2
Part 2 – Operating System Configuration 3
1 System Users 3
1.1. Current configuration potential weakness 3
1.2 Configuration improvement details and **rationale** 3
2 Firewall Configuration 5
2.1 Current configuration potential weakness 5
2.2 Configuration improvement details and rationale 6
3. Hard Drive Encryption 8
3. 1 Current configuration potential weakness 8
3.2 Configuration improvement details and rationale 10
4. Antivirus Software 11
4. 1 Current configuration potential weakness 11
4.2 Configuration improvement details and rationale 13
5. Backup 14
5. 1 Current configuration potential weakness 14
5.2 Configuration improvement details and rationale 15
6. Password manager 16
6. 1 Current configuration potential weakness 16
6.2 Configuration improvement details and rationale 17
Part 3 – Conclusion 18
References 19

Part 1 – Introduction

1. Description of Computer (Hardware and OS Details)

The system is a Lenovo Yoga 6 with an AMD Ryzen 5 7530U processor and 16GB of RAM. It operates on a 64-bit version of Microsoft Windows 11 Home Single Language, 25H2 version.



Device info

Copy

Device name	LenovoYoga6
Processor	AMD Ryzen 5 7530U with Radeon Graphics (2.00 GHz)
Installed RAM	16.0 GB (13.9 GB usable)
Device ID	86909B8B-A305-4604-9DE5-342D55563058
Product ID	00342-42640-14891-AAOEM
System type	64-bit operating system, x64-based processor
Pen and touch	Pen and touch support with 10 touch points

Device insights
Additional information about your device

This operating system

Windows info

Copy

Edition	Windows 11 Home Single Language
Version	25H2
Installed on	1/12/2026
OS build	26200.7462
Experience	Windows Feature Experience Pack 1000.26100.275.0

Microsoft Services Agreement
Microsoft Software License Terms

Figure 1.1: Hardware and OS Details

Part 2 – Operating System Configuration

1 System Users

1.1. Current configuration potential weakness

The system has a single active user account with full superuser privileges. This configuration violates the Principle of Least Privilege, as the primary user has complete administrative controls at all times rather than being restricted to specific administrative privileges, which can result in system exploitation due to malicious software or human error. During a recent attempt to install Ubuntu, unrestricted access to privileges like changing security boot configurations and disk partitions led to the unintended removal of current operating system and caused data loss. This demonstrates how continuous administrative privileges can increase the risk of misconfiguration, accidental data loss and overall system stability.

Based on the current password policy, the system allows passwords to be as short as zero characters, and no password history is maintained therefore, it allows the use of weak and repetitive passwords. Additionally, a relatively high lockout threshold of 10 offers almost no resistance to login attempts, reducing the strength of system authentication. Under such conditions an external adversary can take advantage by performing brute force attack and if successful, they could gain unauthorized access to the system and access sensitive files, stored credentials and potentially result in full system take over.

```
C:\Users\ritup>net accounts
Force user logoff how long after time expires?:       Never
Minimum password age (days):                          0
Maximum password age (days):                          42
Minimum password length:                              0
Length of password history maintained:                None
Lockout threshold:                                    10
Lockout duration (minutes):                           10
Lockout observation window (minutes):                 10
Computer role:                                        WORKSTATION
The command completed successfully.
```

Figure 1.1.1: Password Policy

1.2 Configuration improvement details and **rationale**

To mitigate the identified vulnerabilities, the system needs to be reconfigured to follow the Principle of Least Privilege by creating a standard user account for everyday activities such as web browsing so that admin privileges are used only for critical system level modifications. In addition, the password policy should be hardened by implementing a minimum of 12 characters length, ensuring the mixture of characters in every password and implementing a password history to

prevent the reuse of previously compromised passwords. Additionally, the account lockout threshold should be reduced to 5 attempts limiting the effectiveness of brute force attacks.

By separating standard and admin privileges the chances of human error such as OS wipe are cut down, since admin authentication is needed before changes are made. Password policy of new requirements strengthens security through complexity and lower account threshold further decreases the password guessing attacks attempts. All these measures improve overall system security by limiting unauthorized access and minimizing the consequences of user errors and safeguarding the system and data.

2 Firewall Configuration

2.1 Current configuration potential weakness

While the firewall is active and inbound connections that do not match a rule are blocked by default, outbound connections are allowed unless specifically blocked. In addition, a large number of apps are permitted to communicate through both private and public networks, increasing the attacker surface. This creates a possibility of malicious actor already present in the system to initiate outbound communications through available apps and execute malware to send data or instructions to malicious servers. As a result, there is confidentiality loss, potential privacy violations or legal risks for system owner.

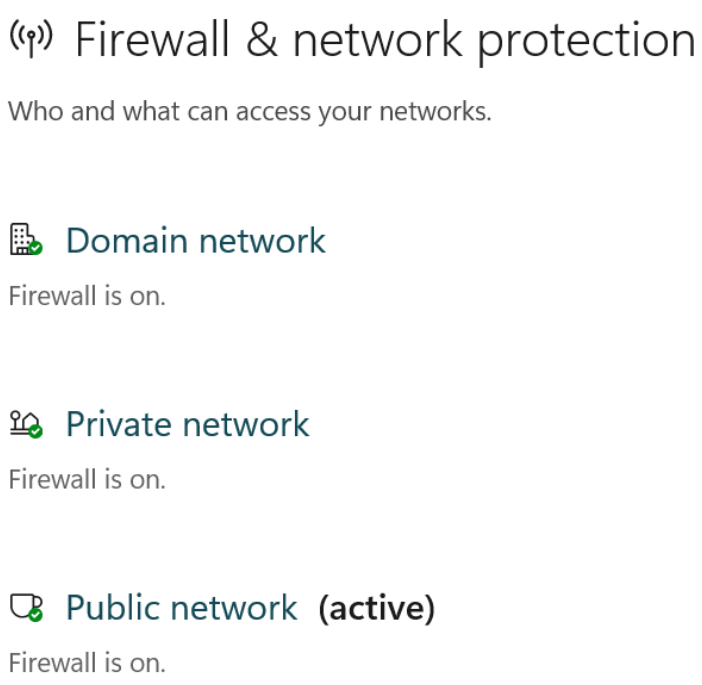


Figure 2.1: Firewall Status for Networks

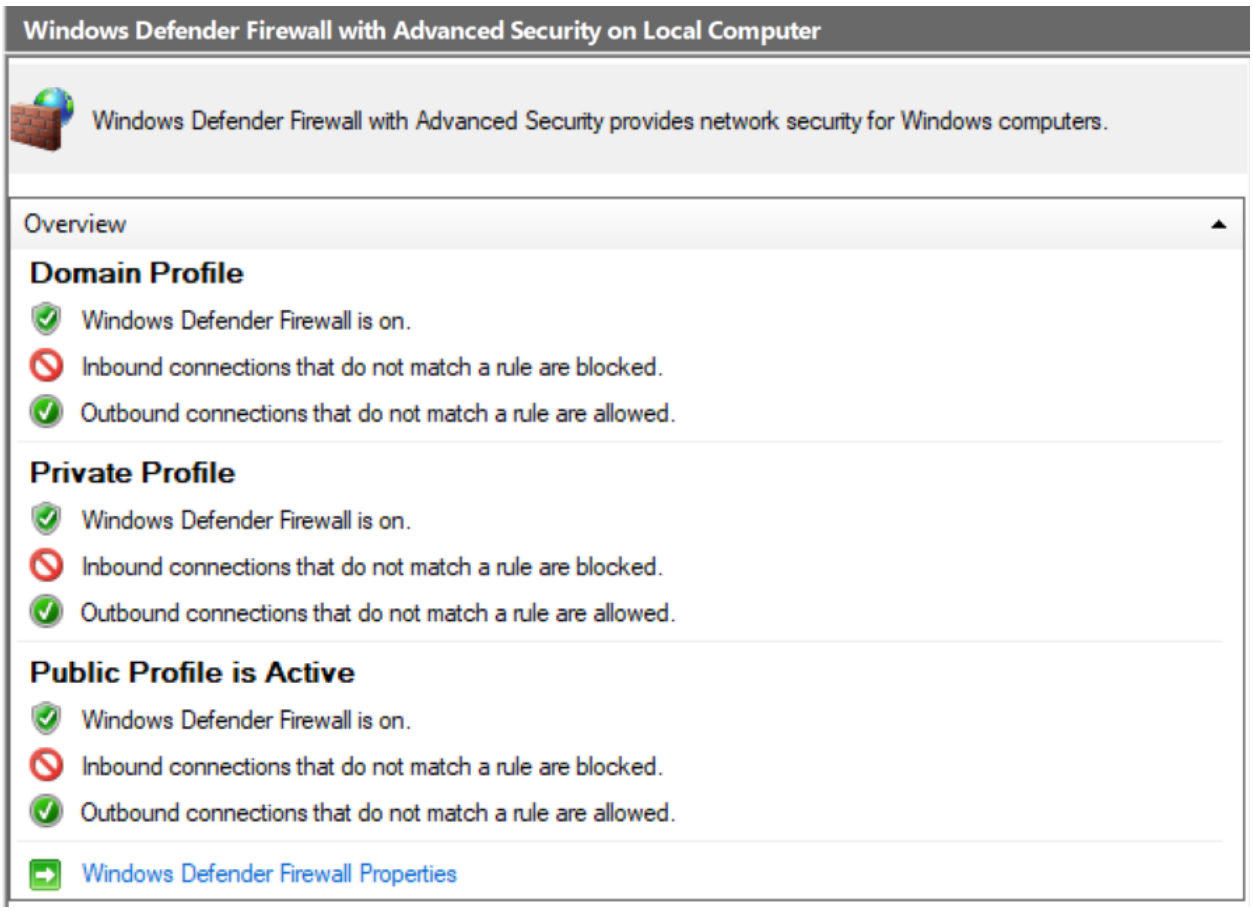


Figure 2.1.2: Inbound and Outbound Firewall Configuration

2.2 Configuration improvement details and rationale

To mitigate the risks, firewall rules should be reconfigured to allow only essential client-initiated communications necessary for normal functioning. Only necessary outbound ports should be allowed and others should be blocked by default. Additionally, the list of apps that are allowed to pass through firewall should be examined carefully and limited to essential and trusted software required for daily tasks. Permissions for non-essential services like remote casting or any unused background features should be removed.

By restricting outbound traffic to only necessary ports, it ensures that an attacker cannot use unauthorized processes to communicate with the external network to send data since only necessary outbound traffic is allowed out. Similarly, by configuring more stringent application rules, reduces the overall attack surface by preventing unnecessary applications from sending or receiving network traffic. These measures taken together reduce opportunities for exploitation and

help protect system confidentiality and integrity by ensuring only approved communications occur.

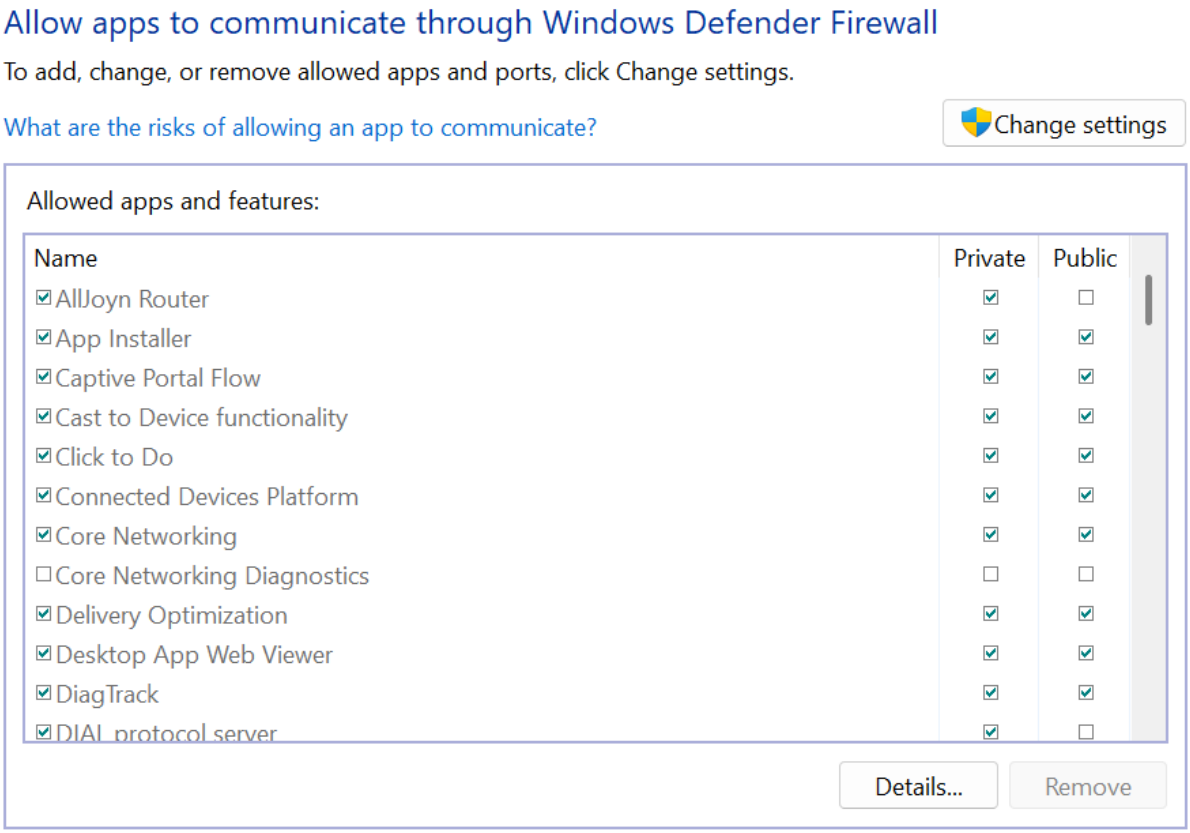


Figure 2.2.1: List of some applications allowed through Windows Defender Firewall

3. Hard Drive Encryption

3. 1 Current configuration potential weakness

In windows 11 Home, disk encryption is offered by a limited version of BitLocker called Device Encryption, which uses the XTS-AES encryption algorithm with a 128-bit key to secure the data on the system drive. The encryption key is automatically unlocked when the operating system is started and does not require additional authentication before; this configuration does not allow the user to add an extra layer of authentication before the operating system is started; hence, the confidentiality of the encrypted data will be largely dependent on the Windows login password. If a skilled attacker gains physical possession of the device in a closed or sleeping state, they may use sophisticated physical attacks such as cold-boot attacks or Direct Memory Access attacks to gain the encryption keys in the system memory. In case the attack is successful, attacker could decrypt the whole disk; resulting in complete loss of sensitive data, credentials, financial information stored on the device.

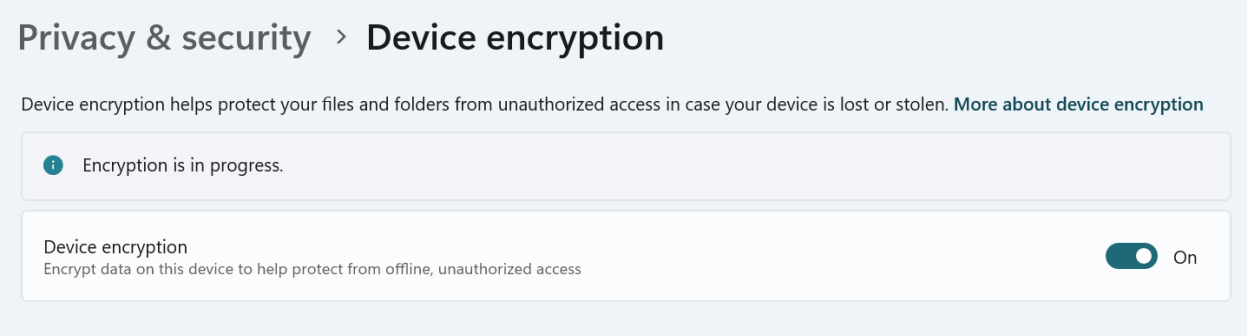


Figure 3.1: Windows Device Encryption Status

Device security

Security that comes built into your device.

Core isolation

Core isolation helps keep your device safe by protecting the Windows kernel.

Core isolation details

Security processor

Your security processor, called the trusted platform module (TPM), is providing additional encryption for your device.

Secure boot

Secure boot is on, preventing malicious software from loading when your device starts up.

Learn more

Data encryption

Helps protect your data from unauthorized access in case your device is lost or stolen.

Figure 3.1.2: Windows Device Security some features overview

3.2 Configuration improvement details and rationale

Since Windows 11 Home Device Encryption uses XTS-AES with a 128-bit key, it also doesn't support any configuration of encryption parameters (such as key length or cipher mode) or pre-boot authentication. As a result, security enhancements must focus on how the system is operated. Specifically, to minimize exposure of encrypted data, Sleep mode should be disabled, and the system should be configured to use Hibernate or full Shutdown when not in use. Furthermore, a strong Windows login password should be used to prevent unauthorized access during normal system operation.

While XTS-AES 128-bit is good enough to protect data at rest, the encryption key automatically unlocks during system startup and remains available while the system is running or sleeping. This weakens it against memory-based physical attacks when the device is left unattended. Avoiding sleep mode and hibernating or shutting down the system not in use means that the encryption key is no longer retained in memory, making cold-boot or DMA attacks considerably less feasible. Strengthens login authentication and limits unauthorized access; together, these measures are intended to reduce full disk decryption risk and protect confidentiality of stored data in case a device is lost or stolen.

4. Antivirus Software

4. 1 Current configuration potential weakness

The system is safeguarded by a Microsoft Defender Antivirus that is active and updated. Besides, it depends on continuous real-time monitoring and Quick Scans rather than scheduled Full Scans. If real-time protection is turned off, delayed, or bypassed, malicious software could run before being detected, and because Quick Scans only review common locations for infections, malware concealed in less frequent areas goes unnoticed. An attacker may introduce a malicious program disguised as a normal file or application that avoids common startup locations and therefore is not detected in the course of routine scans. This allows the malware to stay active on the system for a longer period of time. As a result, personal files and credentials stored could be accessed or transmitted without the user's knowledge, leading to loss of confidentiality and integrity of the system.

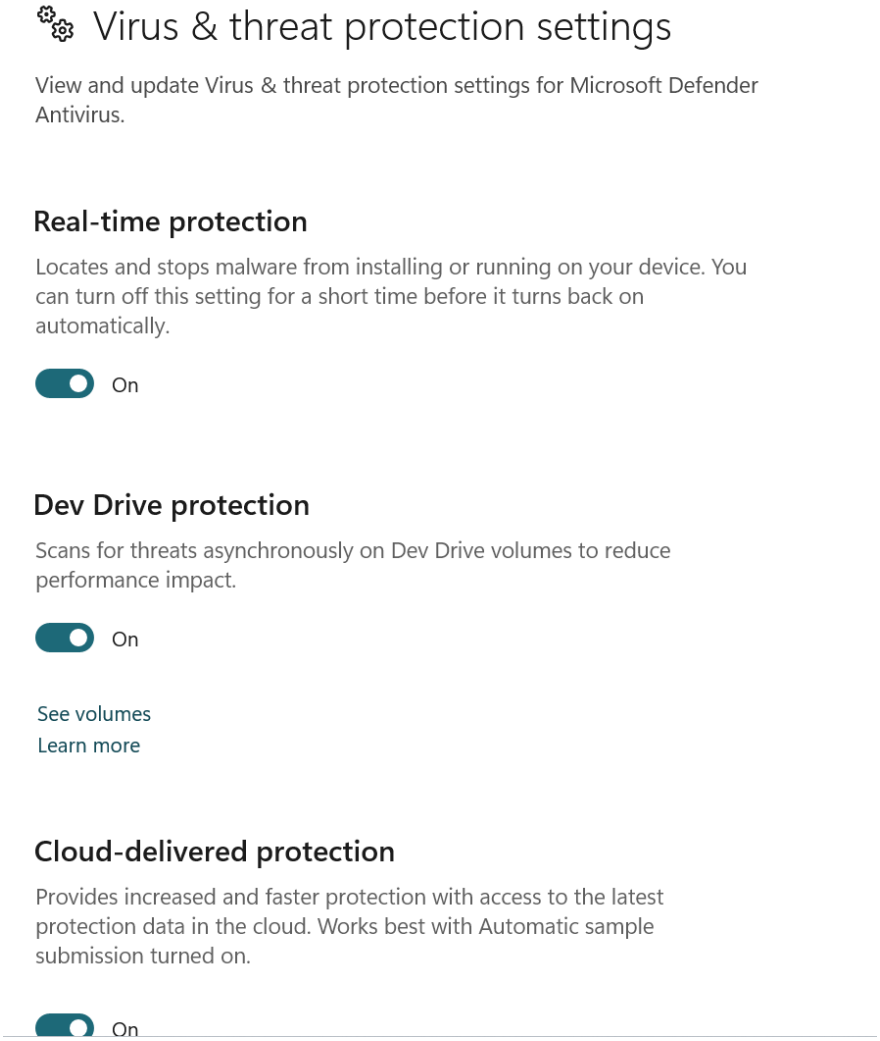


Figure 4.1: Microsoft Defender Antivirus Protection Status

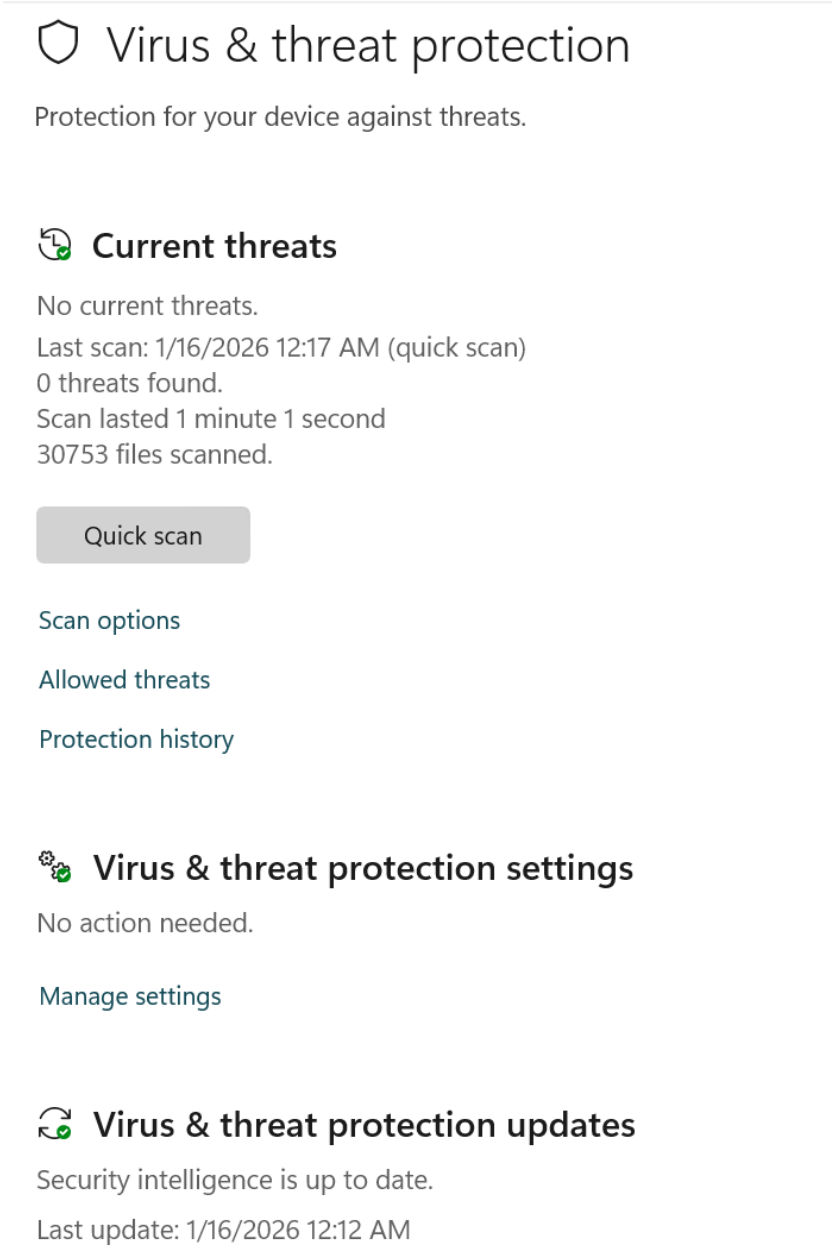


Figure 4.1.2: Microsoft Defender Antivirus Update and Scan Information

4.2 Configuration improvement details and rationale

The antivirus settings should be strengthened by allowing automatic security intelligence updates and performing Full Scans instead of Quick Scans on a regular basis. Full Scans ensures the scanning of all system files and directories, including locations not included in the routine scanning process. Cloud-based security and Tamper Protection should remain enabled to allow application of the latest threat intelligence.

Scheduled Full Scans make it less likely that malware present in non-standard areas remains undiscovered, while constant updates and cloud-based detection make it more effective at dealing with emerging threats. They work collectively to make malware persistence less likely, and reduce the chance of undetected execution, and provides high level of protection for personal files, strengthening the overall system.

5. Backup

5. 1 Current configuration potential weakness

The backup of files is done using Microsoft OneDrive, which performs automatic and continuous synchronization as long as the device is connected to the internet, ensuring that changes in the enabled folders are backed up close to real time. However, the backups are limited to predetermined "Known Folders" such as Documents, Desktop, Pictures, Music, and Videos. In the current configuration, Documents and Desktop are the folders that are backed up, while the rest are disabled, meaning that there is partial backup protection. In addition, OneDrive does not allow users to back up additional local folders. In cases of hardware failure, deletion, and theft of devices, files not in the enabled folders can be either deleted or encrypted without a means to perform recovery. Leading to an irreversible loss of important academic, personal or project-related data not included in the backup solution system.

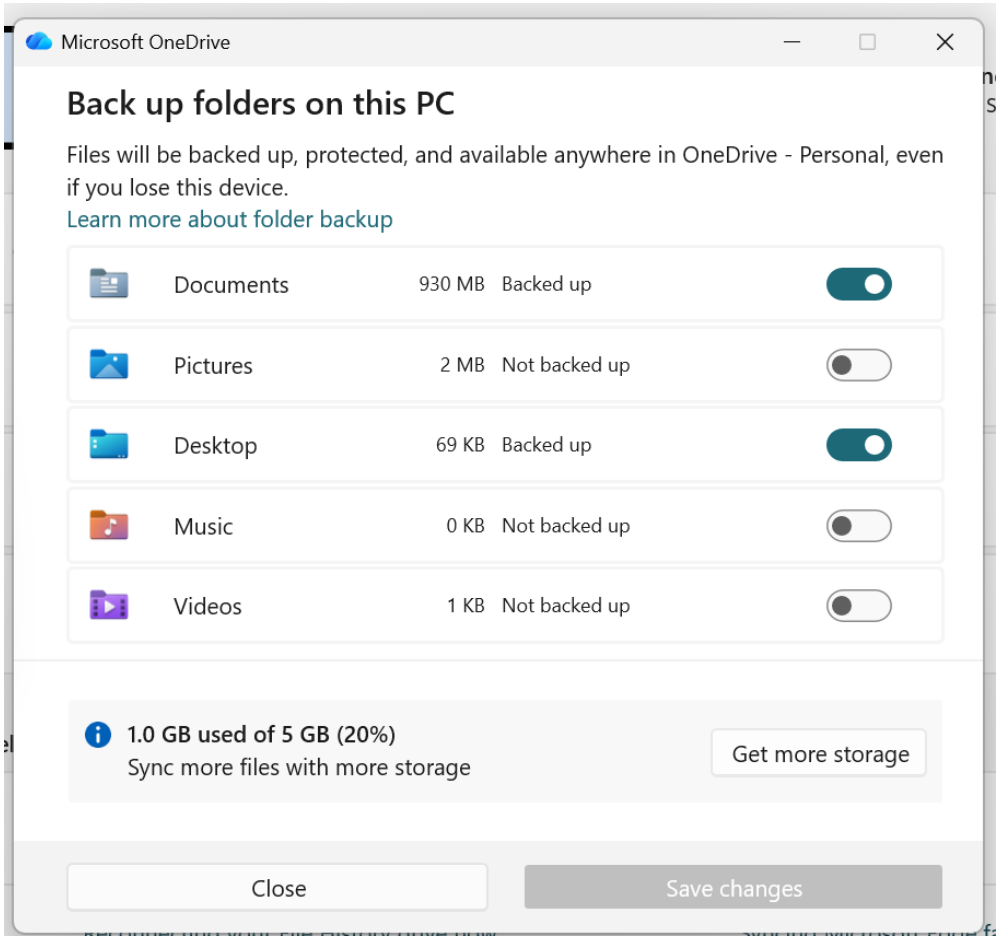


Figure 5.1.1: OneDrive Folders Backup Configuration

5.2 Configuration improvement details and rationale

To minimize risks that come with partial backup protection, the OneDrive settings should be extended to allow backups in all supported folders such as Pictures, Music, and Videos. For documents that are not placed in the predefined known folder, important data has to be moved to backed-up folders. In addition, secondary form of backup, which may be using an external hard drive offline should be implemented.

Extending the backup coverage will help the frequently used personal and academic information to be safe and secure from being deleted, failing, or getting lost. Using a secondary form of backup secures the information and prevents the loss of the data due to the failure of the cloud synchronization and the potential hack of the OneDrive account. Together these measures will help prevent the loss of the data.

6. Password manager

6. 1 Current configuration potential weakness

The system relies on the Microsoft Edge Password Manager to store and manage account credentials. Saved passwords are encrypted using AES and are stored inside the user's Microsoft account linked credential vault. The decryption is carried out by Windows Data Protection APIs (DPAPI). This means the key is dependent on the logged-in Windows user account and is unlocked automatically when the user's Windows credentials or biometric sign-in is entered correctly. Thus, the logged-in credentials are the only protection for the entire set of stored login credentials, which creates a single point of failure. An attacker might gain access to the device through credential theft, shoulder surfing, or temporary physical access while the system is open and unlocked and could access to the edge password vault and obtain the credentials without having to crack the passwords or encryption. This could potentially cause compromise of accounts, including email, cloud storage, and financial sites, and could consequently cause many breaches through linked sites.

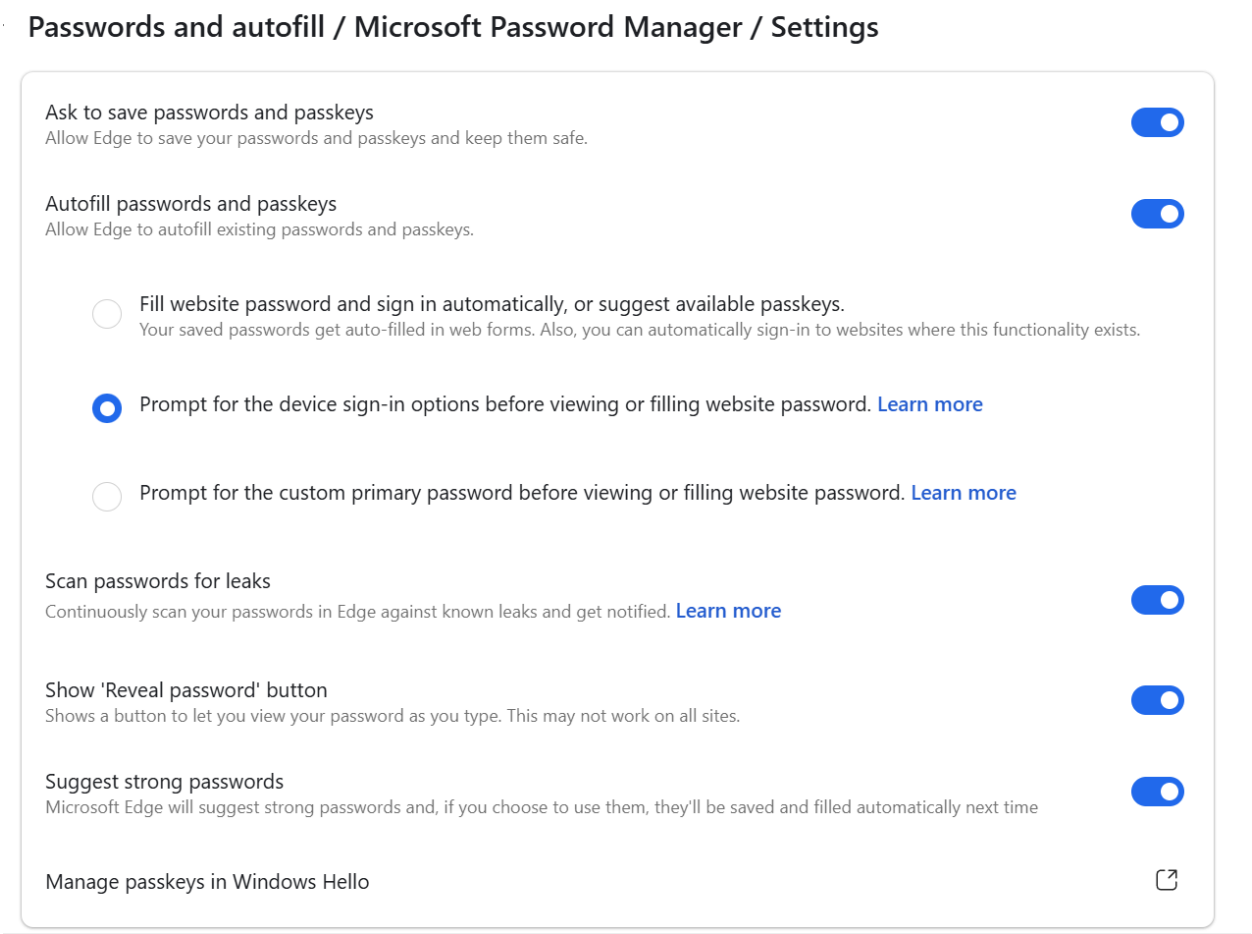


Figure 6.1.1: Microsoft Edge Password Manager Security Settings

6.2 Configuration improvement details and rationale

To mitigate the identified weakness, Microsoft Edge Password Manager should be set up to always require a custom primary/master password prior to viewing or filling saved credentials. This adds an additional layer of authentication on top of Windows login, ensuring that stored passwords cannot be accessed immediately after device login.

Requiring a master password blocks the attack path where an attacker after gaining physical access to the device may expose the whole credential vault. Even when unlocked, the system allows saved credentials to remain protected. Additionally using a password manager, also enables strong and unique passwords for each account, thereby minimizing password reuse and reducing the impact of credential compromise, thus helping to further ensure data confidentiality regarding personal, academic, and financial information.

Part 3 – Conclusion

Before the hardening process, the system relied largely on default security settings, that exposed it to many vulnerabilities. The lack of adherence to the Principle of Least Privilege made it more susceptible to accidental damage of the system, as shown during the unsuccessful dual-boot installation. Weak password policies made authentication less secured, while permissive firewall policies, quick antivirus scans, and partial backup of data expanded the attack surface. Even though disk encryption and password manager were in use, their effectiveness had been compromised by Windows 11 Home and dependence on single login, leaving sensitive data vulnerable.

After implementing the hardening measures, the security posture of the system was significantly strengthened. The privilege separation has mitigated risks of attacks from user negligence and malware attacks. The use of strong passwords has strengthened resistance to brute force attacks. The firewall and antivirus controls have reduced risks of network and malware-based attacks. The operational measures have enhanced disk encryption protection and adding a master password in the password manager has reduced the risk of large-scale credential compromise. All these measures have minimized risks associated with attacks. Strengthened access controls, and improved confidentiality, integrity and availability of system data, resulting in a secure resilient system.

References

[1] BitLocker and Device Encryption Overview: BitLocker Overview - Microsoft Learn

[2] Microsoft Defender Cloud-Delivered Protection: Turn on cloud protection in Microsoft Defender Antivirus

[3] OneDrive Ransomware Recovery and Protection: Ransomware detection and recovering your files - Microsoft Support

[4] Windows Hello and TPM Security: TPM recommendations | Microsoft Learn

[5] Principle of Least Privilege (PoLP): Windows Administrator Accounts Guideline - Carnegie Mellon University

[6] Windows 11 Firewall Best Practices: Windows 11 Firewall Best Practices: Eight Steps to Harden Host Security